Week 3, Task 10 — Phase A Summary

S3 Misconfiguration Risks, Encryption and Access Control

Common Misconfigurations and Mitigations

Unintended **public-read access** can expose customer records, backups or credentials. Public-write permissions can permit unauthorized uploads or overwrites, depending on the actions granted. Broad IAM permissions can also allow a compromised identity to access more resources than necessary.

Mitigations include enabling S3 Block Public Access, removing unnecessary public grants, keeping ACLs disabled and restricting permissions to required actions and resources. Credential-bearing files should be removed from exposed storage, and disclosed keys should be revoked or rotated.

Three Real-World Exposure Examples

- **Verizon partner, 2017:** A publicly accessible S3 repository exposed customer information, illustrating the need to review third-party storage permissions.
- **Accenture, 2017:** Publicly accessible buckets exposed sensitive information, including credentials, demonstrating how storage misconfigurations can create further access risks.
- **Booz Allen Hamilton/NGA, 2017:** An unsecured S3 repository exposed sensitive files and access credentials, highlighting the consequences of inadequate access restrictions.

These cases document public exposure; they do not independently establish malicious exploitation.

SSE-S3 Compared with SSE-KMS

SSE-S3	SSE-KMS
S3 manages encryption keys.	Encryption uses AWS KMS keys.
No additional encryption charge.	Additional KMS charges can apply.
S3 permissions control object access.	Access also requires applicable KMS permissions.
Simple encryption-at-rest configuration.	Supports additional key governance and key-use auditing.

New S3 uploads receive encryption at rest automatically. SSE-KMS adds key-level controls, but neither option replaces secure S3 permissions.

IAM Roles, Bucket Policies and Object ACLs

IAM roles provide assumable identities with temporary credentials. Their attached policies define permitted actions. Bucket policies control access to buckets and objects, while ACLs provide legacy permission grants when enabled.

AI-assisted comparison: A bucket policy supports specific principals, actions, resources, conditions and explicit denies. An object ACL provides limited grants for an individual object without conditions or explicit denies. Bucket policies can target individual objects, so object-specific access does not require ACLs. AWS recommends keeping ACLs disabled for most use cases.

Key Learning

Effective S3 protection combines access restrictions, appropriate encryption and monitoring. A denied request alone does not prove that every object or access path is secure.

AI assistance: ChatGPT supported concept explanation, comparison and drafting.

References: AWS S3 Security Best Practices; AWS SSE-KMS documentation; UpGuard’s Verizon, Accenture and Booz Allen Hamilton exposure reports.
